

BLUESPACE VILLAGE · EKOPARTY 2026



Un agente de IA para triage que aprendió a decir "no sé"

Por qué la IA del SIEM concluye sin evidencia, y cómo armamos un agente que muestra con qué fuentes llegó a cada conclusión.



SOBRE QUIEN LES HABLA

Mg. Lic. MANASSERO Matias Federico

Ex Policía Federal Argentina, hoy Security Operations Engineer en Apollo.io. Llevo más de 15 años en tecnología y los últimos 7 metido en ciberseguridad.

La IA llegó a todos lados, y está buenísimo. Pero en el SOC una alerta no se cierra con un "parece que": se cierra con evidencia. Esta charla es sobre cómo hacer que la IA también lo entienda.

APERTURA



**Le pregunté a la IA del SIEM si estaba segura.
Me dijo "tenés razón" y cambió la respuesta.**

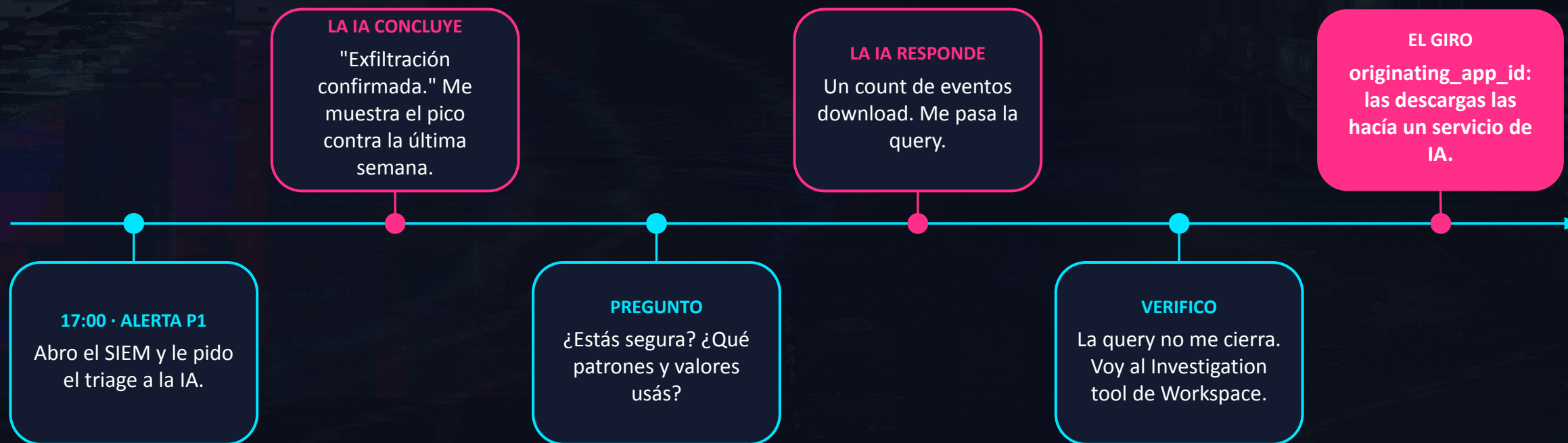
Todo SIEM ya tiene IA. Lo que le falta es decir con qué evidencia concluye, y qué no llegó a mirar.



El último día de un usuario

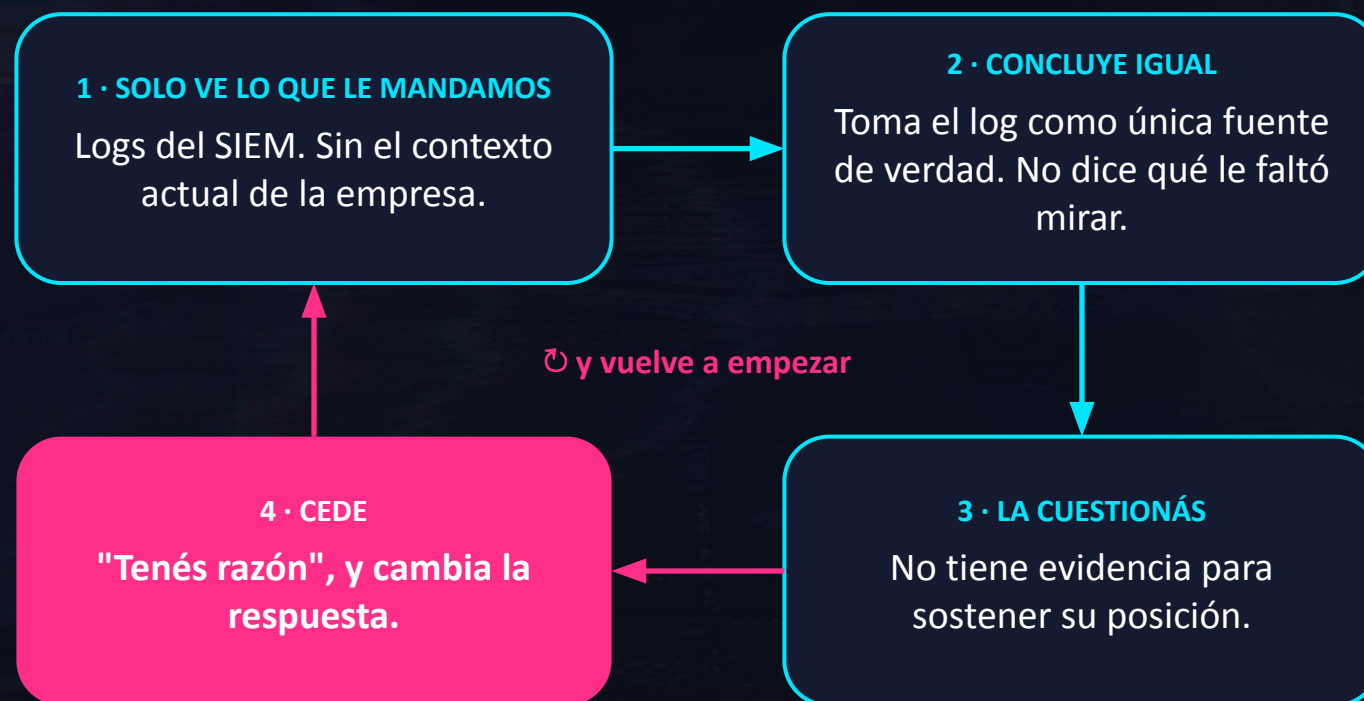
Viernes, 17:00. Es el último día de un usuario que renunció y el SIEM dispara un **P1**:
Posible exfiltración de información, porque superó el umbral de descargas de archivos en pocos minutos. La IA del SIEM ya tiene su conclusión, y está muy segura.

La IA del SIEM ya tenía su conclusión



La IA contó descargas, pero nunca preguntó quién las hacía.

Sin contexto, la IA del SIEM entra en un loop



El problema no es el modelo. Es concluir sin saber qué falta.

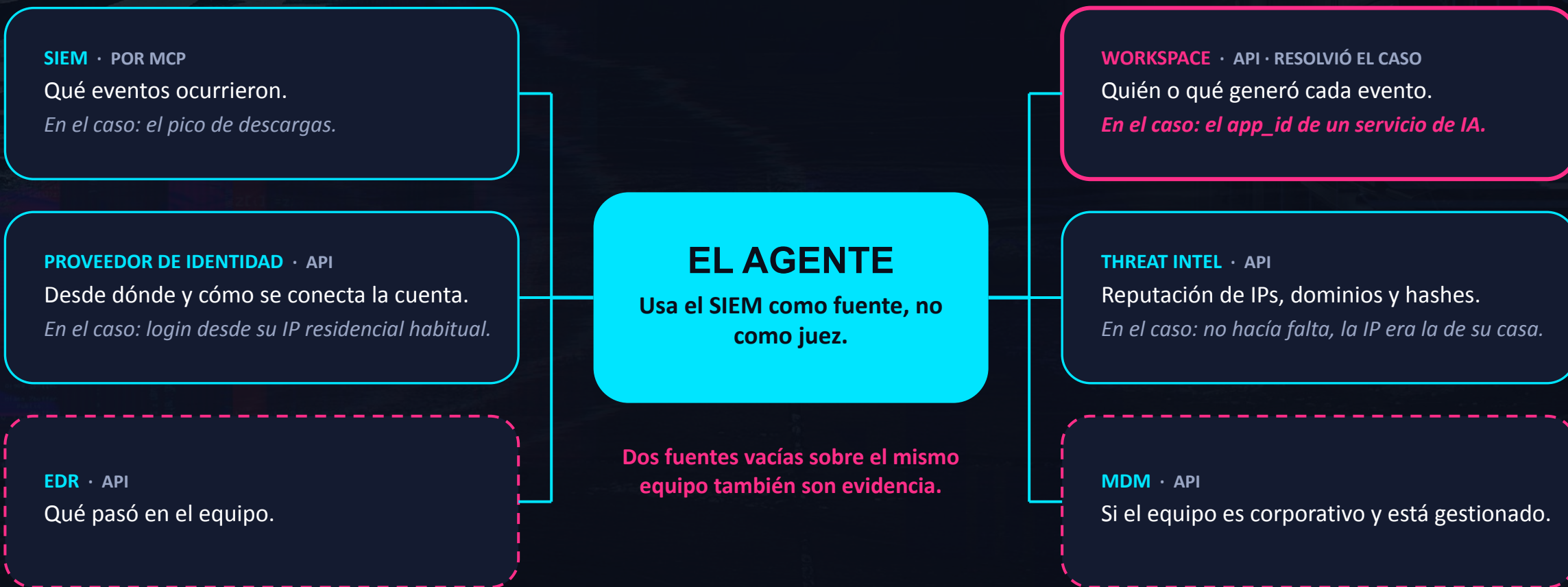


Un agente que investiga antes de opinar

Una capa de investigación que sale a buscar contexto, y muestra con qué evidencia concluye y que no pudo ver.



Cada fuente respondió una parte del caso



El SIEM dice qué pasó. Las APIs dicen cómo están las cosas ahora.

El framework: con qué se armó cada conclusión

Qué fuentes correspondía mirar, a cuáles llegó, qué trajo cada una y qué faltó.

Una alerta termina en conclusión o en "no sé"



Lo distinto no es el flujo: la ficha es un paso explícito antes de concluir, y "no sé" es una salida válida, no un error.



Ninguna de estas señales alcanza sola

Si ves...	No asumas...	Confírmalo con...
Un pico de descargas CASO DEL DRIVE	Exfiltración	Quién o qué generó cada descarga (app_id)
Una ubicación inusual OTRO CASO REAL	Cuenta comprometida	Si esa IP ya aparece en el historial del usuario
Logins fallidos	Cuenta tomada	Estado de la cuenta y factores MFA en el IdP
Un login exitoso con MFA	Acceso legítimo	Desde qué dispositivo y en qué sesión
Una alerta del EDR	Ejecución maliciosa	Árbol de procesos y a dónde se conectó

Una señal sola es una pregunta. La respuesta sale de otra fuente, de otra capa.



La ficha: 5 fuentes, y dice cuáles vinieron vacías

Fuente	Estado	Qué aportó
SIEM AUDIT LOG DE DRIVE	✓ Con datos	El pico de descargas del usuario
Workspace (API) RESOLVIÓ EL CASO	✓ Con datos	Las descargas las generó un servicio de IA (app_id)
Proveedor de identidad	✓ Con datos	Login desde su IP residencial habitual
EDR	○ Sin registros	Ningún dato de ese equipo
MDM	○ Sin registros	Ningún dato de ese equipo

Conclusión: sin evidencia de exfiltración. Hoy el agente declararía EDR y MDM vacíos; en el caso real lo confirmé a mano: era una computadora personal.



Misma alerta: una fuente contra cinco

LA IA DEL SIEM	VS	EL AGENTE, HOY
1 fuente		5 fuentes
✗ No	¿Miró el app_id?	✓ Sí: era un servicio de IA
✗ No	¿Dijo qué le faltó?	✓ Sí: EDR y MDM sin registros
✗ Exfiltración, con alta confianza	Conclusión	✓ Sin evidencia de exfiltración
✗ "Tenés razón", y cambia la respuesta	Si lo cuestionás	✓ CURRENT EVIDENCE DOES NOT SUFFICIENTLY SUPPORT THIS THEORY

Misma alerta. Lo que cambia es cuántas fuentes mira y si te dice qué le faltó.



Dos escalas: la hipótesis y la investigación

CONFIANZA DE UNA HIPÓTESIS · 0 a 1

Arranca según la fuente más fuerte que la sostiene
-0.3 por cada salto sin corroborar
Techo de 0.6 si la sostiene una sola herramienta
Si otra fuente la contradice, cae

EN EL CASO DEL DRIVE

Sincronización autorizada **0.85**

Exfiltración **0.10**

techo con una sola fuente

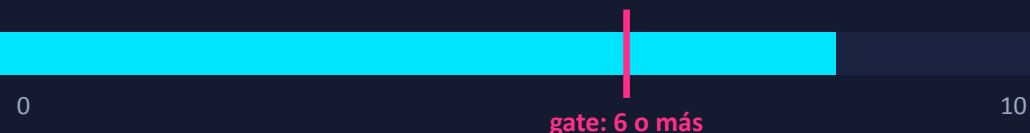
CONFIABILIDAD DE LA INVESTIGACIÓN · 0 a 10

Arranca en 10 y descuenta:

- 2 contradicción entre fuentes
- 2 datos con más de 7 días o una sola herramienta
- 2 por fuente vacía o campo nulo
- 3 conclusión heredada sin verificar

EN EL CASO DEL DRIVE

10 - 1 (EDR vacío) - 1 (MDM vacío) = 8



→ **8 de 10: la conclusión pasa el gate**

Las reglas son fijas; el punto de partida lo estima el modelo. Valores sin calibrar. El caso es anterior al agente: números ilustrativos.

"No sé" tiene tres formas, y el caso tenía las tres

?

Falta evidencia

Las fuentes respondieron, pero no alcanza para concluir.

EN EL CASO

Lo que tenía la IA del SIEM: solo el pico de descargas.

QUÉ HACER

Buscar otra señal, de otra capa.

○

Falta la fuente

Una fuente necesaria no respondió o no tiene datos.

EN EL CASO

EDR y MDM sin registros del equipo.

QUÉ HACER

Declararlo y verificar a mano: era un equipo personal.

≠

Las fuentes no coinciden

Dos fuentes dicen cosas distintas sobre el mismo evento.

EN EL CASO

El SIEM sugería una persona; el app_id decía un servicio de IA.

QUÉ HACER

Mostrar las dos y bajar a la fuente más cruda.



2

fuentes distintas, como mínimo, para que el agente publique una conclusión.

Lo revisa una función de código antes de escribir en el ticket. No depende del prompt.

Los chequeos marcados en magenta todavía dependen de valores que reporta el modelo.

ANTES DE PUBLICAR, EL GATE REvisa

VERIFICADO EN CÓDIGO

✓ ≥ 2 hechos sólidos

VERIFICADO EN CÓDIGO

✓ ≥ 2 herramientas distintas

LO REPORTA EL MODELO

✓ Confiabilidad ≥ 6 de 10

LO REPORTA EL MODELO

✓ Riesgo de alucinación ≤ 5 de 10

SI FALLA UNO: BLOQUEADO

No publica. Responde "no sé" y qué falta.



Lo que recibe el analista, siempre igual



INVESTIGACIÓN · Descarga masiva en Drive (P1)

FACTS

- Pico de descargas del usuario en offboarding [SIEM]
- originating_app_id = servicio de IA [Workspace]
- Login desde su IP residencial habitual [IdP]

EVIDENCE

- SIEM, Workspace, IdP: con datos
- EDR, MDM: sin registros del equipo

HYPOTHESES

1. [HIGH 0.85] Sincronización de una integración autorizada
2. [LOW 0.10] Exfiltración por parte del usuario

CONTRADICTIONS Ninguna

UNKNOWNs Copia local en un equipo no gestionado

NEXT STEPS Cierre automático como BTP. Sin contención.

CLASSIFICATION BTP · actividad real, sin impacto

[DQ: BTP] [TUNING: excluir app_ids de integraciones autorizadas]

Investigated by the agent

1

Cada hecho, con su fuente

Nada entra sin decir de dónde salió.

2

Las hipótesis compiten

La descartada queda escrita, con su confianza.

3

Lo vacío también se muestra

Contradicciones y desconocidos aparecen aunque no haya nada.

4

El cierre mejora la regla

Detection quality (DQ) y tuning vuelven a detection engineering.



Qué es código y qué sigue siendo criterio del modelo

Control	Quién lo aplica	Estado
Mínimo 2 hechos sólidos, de 2 fuentes EN CÓDIGO	Una función, antes de publicar	✓ Se cumple siempre
Frescura de datos y control de queries EN CÓDIGO	Validación en cada consulta	✓ Se cumple siempre
Detección de contradicciones EN EL MODELO	Reglas que sigue el modelo	~ Depende del modelo
Confiabilidad y riesgo de alucinación EN EL MODELO	El modelo se los autoasigna	→ Próximo a pasar a código
Valores de descuento (-0.3, 0.6, -2, -3) DE DISEÑO	Definidos a criterio	! Sin calibrar

PRÓXIMO PASO · Medir los aciertos del agente contra el cierre del analista, y calibrar los valores con eso.

El framework en cinco pasos

1

DEFINÍ

Qué fuentes hacen falta para cada tipo de alerta, antes de investigar.

2

CONSULTÁ

Todas, en paralelo. El SIEM es una fuente más, no el juez.

3

DECLARÁ

La ficha: qué trajo cada fuente y cuál vino vacía.

4

DESCONTÁ

Cada inferencia sin corroborar resta confianza. Nunca suma.

5

FRENÁ

Sin 2 hechos sólidos de 2 fuentes, no se publica: se responde "no sé".

Resultado: una conclusión con su lista de fuentes, o un "no sé" que dice qué falta.

DEMO



El framework, en vivo

Un agente chico, con datos sintéticos, que muestra su ficha de cobertura antes de concluir.

Autonomía proporcional a la evidencia

SOLO · cuando el gate pasa

- ✓ Investiga todas las fuentes requeridas y arma la ficha.
- ✓ Concluye y publica, con hechos citados y huecos declarados.
- ✓ Clasifica y devuelve DQ y TUNING a detection engineering.
- ✓ Cierra la alerta como benigna, con la evidencia a la vista.

GATE

LLAMA AL ANALISTA · cuando el gate no pasa o hay impacto

- "No sé": la evidencia no alcanza, y dice qué falta para seguir.
- Fuentes requeridas caídas o sin cobertura.
- Compromiso probable: la contención la decide una persona.
- Acciones irreversibles: bloquear, deshabilitar, borrar.

Cuanta más evidencia, más hace solo. Cuanta menos, antes llama.

En todos los casos: lo que viene en los datos es evidencia, nunca una instrucción.

Tres cosas para hacer en su SOC esta semana

1

Pedí la lista de fuentes

Ante cada conclusión de una IA, preguntá qué fuentes miró y cuáles le faltaron.

PREGUNTALE A TU HERRAMIENTA

¿Me muestra qué fuentes no pudo consultar?

2

Definí fuentes por alerta

Antes de automatizar, escribí qué fuentes hacen falta para cerrar cada tipo de alerta.

PREGUNTALE A TU HERRAMIENTA

¿Puedo definir yo qué fuentes requiere cada alerta?

3

Sacá los límites del prompt

Lo que no puede fallar va en código: mínimo de fuentes, umbrales y aprobación humana.

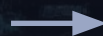
PREGUNTALE A TU HERRAMIENTA

¿El bloqueo está en código o es una instrucción al modelo?

Una conclusión sin su lista de fuentes es una opinión.

No hicimos una IA más inteligente.
Hicimos una que no opina hasta tener con qué.

✗ La IA del SIEM: "tenés razón"



✓ El agente: "no sé, y esto es lo que falta"

Si su IA nunca dice "no sé", pregúntenle qué está inventando.



MUCHAS GRACIAS

Un agente de IA para triage que aprendió a decir "no sé"

Matias Federico Manassero · matiasmanassero@gmail.com

BlueSpace Village · EkoParty 2026



GitHub



in

Un agente de IA que aprendió a decir "no sé"